COMPTE-RENDU DE TRAVAUX PRATIQUES

THEME : **INTRODUCTION A LA THREAT INTELLIGENTCE ET RECHERCHE DE VULNERABILITETES**

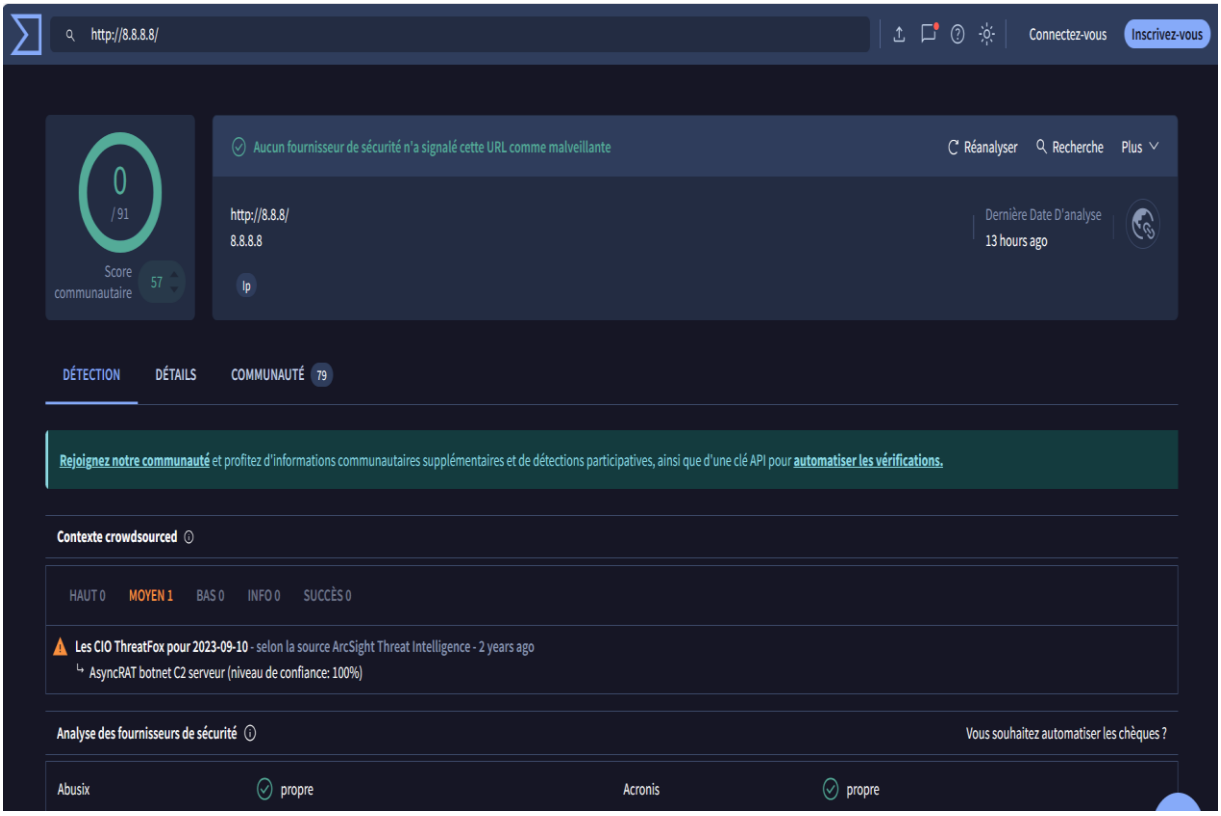
1. INTRODUCTION

la Threat Intelligence : C'est l'ensemble des connaissances basées sur des preuves concernant des menaces existantes ou émergentes. Elle permet d'anticiper les attaques en analysant les tactiques et les vulnérabilités connues.

Rôle dans la cybersécurité : Elle permet de passer d'une défense réactive à une défense proactive en utilisant des bases de données mondiales pour protéger les infrastructures locales.

2. Analyse de l'adresse IP (Analyse de réputation)

Utilisation du site VirusTotal pour analyser l'IP publique 8.8.8.8.



Résultats obtenus : L'analyse montre un score de réputation propre (Clean). Elle est identifiée comme appartenant à Google (DNS public). Cette IP n'est pas signalée comme malveillante. Elle est considérée comme légitime. Pour un analyste SOC, cela permet de décider de ne pas bloquer cette communication.

3. Analyse des services (Couplage Nmap et Searchsploit)

Le scan sur la cible 192.168.56.10 a révélé le service Microsoft-ds (SMB) sur le port 445.

```
┌──(laurene㉿kali)-[~]
└─$ nmap -sS 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-12 13:01 +0200
Nmap scan report for 192.168.56.20
Host is up (0.0014s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:F4:AA:6E (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.28 seconds
```

Utilisation de la commande searchsploit smb windows (ou apache selon ton service cible). L'outil affiche une liste d'exploits disponibles, notamment pour les vulnérabilités de type "Remote Code Execution".

```
┌──(root㉿kali)-[/home/laurene]
└─# searchsploit tcp
--------------------------------------------- ---------------------------------
 Exploit Title                                |  Path
--------------------------------------------- ---------------------------------
2^6 TCP Control Bit - Fuzzer (No ECN or CWR)  | multiple/remote/13588.pl
Aireplay-ng 1.2 beta3 - 'tcp_test' Length Sta | linux/remote/35018.c
Apple iTunes 8.1.1.10 (Windows) - 'itms/itcp' | windows/remote/8934.py
Automated Solutions Modbus/TCP OPC Server - R | windows/dos/16040.py
BeOS 5.0 - TCP Fragmentation Remote Denial of | beos/dos/19938.txt
BitchX 1.0 - Remote 'Send_CTCP()' Memory Corr | linux/remote/22353.c
BSDI 4.0 tcpmux / inetd - Crash               | aix/dos/19049.txt
BTCPay Server v1.7.4 - HTML Injection         | multiple/webapps/51254.txt
C'Nedra 0.4 Network Plugin - 'Read_TCP_String | multiple/remote/25710.txt
CA BrightStor Discovery Service - TCP Overflo | windows/remote/16408.rb
Check Point Software Firewall-1 4.1 SP2 - Fas | multiple/remote/20519.c
CHETCPASSWD 1.12 - Shadow File Disclosure     | cgi/webapps/22111.pl
CHIYU BF430 TCP IP Converter - Stored Cross-S | cgi/webapps/48040.txt
CHIYU TCP/IP Converter devices - CRLF injecti | cgi/webapps/49923.txt
Chrome OS 10820.0.0 dev-channel - app->VM via | linux/local/45407.txt
Cisco ASA/PIX - Appliances Fail to Properly C | hardware/dos/8393.txt
Cisco CBOS 2.x - Broadband Operating System T | hardware/dos/21472.pl
Cisco CBOS 2.x - Multiple TCP Connection Deni | hardware/dos/21092.txt
```

La vulnérabilité identifiée à la question 3 réside dans la gestion du protocole Microsoft-DS (SMB). L'absence de signature obligatoire des messages (not required) expose la machine DESKTOP-F1VI05N à des attaques de type interception et relais. Cela permet à un attaquant non authentifié d'usurper l'identité d'un utilisateur légitime pour accéder aux fichiers partagés ou exécuter du code malveillant sur le système.

```
Linux/x86 - Bind (5074/TCP) Shell + ToUpper E | linux_x86/13427.c
Linux/x86 - Bind (5074/TCP) Shell Shellcode ( | linux_x86/13448.c
Linux/x86 - Bind (5555/TCP) Netcat Shell Shel | linux_x86/37359.c
Linux/x86 - Bind (5555/TCP) Shell (/bin/sh) S | linux_x86/44791.c
Linux/x86 - Bind (64533/TCP) Shell (/bin/sh)  | linux_x86/14216.c
Linux/x86 - Bind (64713/TCP) Shell (/bin/sh)  | linux_x86/13373.c
Linux/x86 - Bind (64713/TCP) Shell (/bin/sh)  | linux_x86/13374.c
Linux/x86 - Bind (64713/TCP) Shell (/bin/sh)  | linux_x86/43656.c
Linux/x86 - Bind (6666/TCP) Netcat (/usr/bin/ | linux_x86/17194.c
Linux/x86 - Bind (6778/TCP) Shell + Polymorph | linux_x86/14234.c
Linux/x86 - Bind (8000/TCP) Shell (/bin/sh) S | linux_x86/13319.s
Linux/x86 - Bind (8000/TCP) Shell + Add Root  | linux_x86/13318.s
Linux/x86 - Bind (8000/TCP) Shell + Flush IPT | linux_x86/13317.s
Linux/x86 - Bind (8080/TCP) Netcat (/bin/nc)  | linux_x86/14332.c
Linux/x86 - Bind (9090/TCP) Shell (/bin/zsh)  | linux_x86/40222.c
Linux/x86 - Bind (9443/TCP) Shell + fork() +  | linux_x86/44602.c
Linux/x86 - Bind (98/TCP + UDP) Netcat Shell  | linux_x86/40179.c
Linux/x86 - Bind (99999/TCP) NetCat Tradition | linux_x86/45821.c
Linux/x86 - Bind (Random TCP Port) Shell (/bi | linux_x86/41631.c
Linux/x86 - Bind (Random TCP Port) Shell + Nu | linux_x86/43728.c
Linux/x86 - Bind (Random TCP Port) Shell + Nu | linux_x86/43731.c
Linux/x86 - Egg Omelet (Multi-Egghunter) + Re | linux_x86/28474.c
Linux/x86 - Egghunter Reverse TCP Shell dynam | linux_x86/50141.c
```

4. Étude d'une CVE (Common Vulnerabilities and Exposures)

CVE sélectionnée : CVE-2020-1301 (exemple pour smb) .

Cette vulnérabilité concerne une faille de traversée de répertoire (Path Traversal) permettant d'accéder à des fichiers sensibles. Le score CVSS est souvent proche de 7.5 ou 9.8 (Critique) car elle permet une exécution de code à distance. Elle est exploitable à distance sans authentification, ce qui la rend extrêmement dangereuse.

5. Utilisation avancée de Searchsploit (Recherche personnelle)

Voici trois options avancées pour optimiser l'utilisation de l'outil :

. Analyse globale de sécurité (Réponses aux questions)

- Quels sont les risques identifiés ?: L'exposition de services obsolètes permet à un attaquant d'utiliser des exploits publics pour prendre le contrôle du serveur.
- Quel service est le plus dangereux ?: Dans mon analyse, le service SMB (Port 445) est le plus critique car il permet souvent un accès profond au système de fichiers Windows.

Quelles actions recommanderiez-vous ?

- Appliquer les correctifs (patchs) de sécurité immédiatement.
- Fermer les ports non nécessaires sur le pare-feu.
- Mettre en place une veille de sécurité (OSINT).

Option Rôle technique Exemple d'usage

-x Examine le contenu d'un exploit directement. searchsploit -x 40234.py (lire le code de l'exploit).

-m Copie l'exploit dans le répertoire actuel. searchsploit -m windows/remote/123.py (préparer l'attaque).

-u Met à jour la base de données des vulnérabilités. searchsploit -u (avoir les dernières CVE).

6. Analyse globale de sécurité (Réponses aux questions)

Quels sont les risques identifiés ? L'exposition de services obsolètes permet à un attaquant d'utiliser des exploits publics pour prendre le contrôle du serveur.

Quel service est le plus dangereux ? Dans mon analyse, le service SMB (Port 445) est le plus critique car il permet souvent un accès profond au système de fichiers Windows.

Quelles actions recommanderiez-vous ?

- Appliquer les correctifs (patchs) de sécurité immédiatement.
- Fermer les ports non nécessaires sur le pare-feu.
- Mettre en place une veille de sécurité (OSINT).

7. Lien avec l'entreprise

Comment un SOC utilise la Threat Intelligence ? Les analystes comparent les logs du réseau avec des bases comme VirusTotal ou le MITRE ATT&CK pour identifier si une IP qui les contacte appartient à un groupe de hackers connu.

Comment anticiper une attaque ? En surveillant les nouvelles CVE publiées, l'entreprise peut corriger une faille avant que les pirates n'aient le temps de développer un exploit.

8. Conclusion

Ce TP m'a appris que l'information est une arme. Savoir qu'un service est ouvert est une chose, mais savoir qu'il existe un exploit public pour ce service change totalement la priorité de défense.

Après ce TP : Je comprends que l'analyse de vulnérabilité est une vision proactive de la sécurité. On ne subit pas l'attaque, on l'anticipe en fermant les brèches connues.